PROJECT REPORT

Dharmsinh Desai University, Nadiad

Faculty of Technology

Department of Computer Engineering

B. Tech. CE Semester – VI

Subject: System Design Practice

Project Title : Sanrakshan

By :

Nisarg Amlani (CE001) , 22CEUEG082
Kavya Shah (CE080) , 22CEUON105

Guided By : Prof. Jigar M. Pandya

Dharmsinh Desai University

Faculty of Technology, College Road, Nadiad – 387001, Gujarat

CERTIFICATE

This is to certify that the term work carried out in the subject of (CE625) System Design Practice and submitted is the bonafide work of Mr. Nisarg Amalani ,Kavya Shah Roll No.: CE001, CE080 Identity No. : 22CEUON105, 22CEUEG082 of B.Tech. Semester VI in the branch of Computer Engineering during the academic year 2024-2025.

Prof. Jigar. M.Pandya	**Dr. C.K. Bhensdadia**
Associate Professor	**Head, CE Department**

Index

Sanrakshan - AI Powered Privacy Policy Analyzer

1. Introduction

Overview

Sanrakshan is an AI-powered privacy policy analyzer designed to help users understand complex privacy policies by identifying potential legal violations and harmful clauses. The platform leverages **Google OAuth** for authentication, **Google's Gemini AI** for analysis, and a **subscription-based model** to provide full access to the analysis. By automating privacy policy evaluations, Sanrakshan empowers users with better insights into how their data is handled. Sanrakshan is live at sanrakshan.xyz.

Objectives

- Provide automated privacy policy analysis using AI.
- Highlight sections that may violate government regulations or user rights.
- Offer a structured breakdown of privacy policies.
- Enable premium users to access a full in-depth analysis.

Key Features

- **User Authentication**: OAuth2 login for secure access.
- **AI-Powered Analysis**: Uses Gemini AI for text evaluation.
- **Temporary Storage**: Utilizes Redis for handling uploaded files.
- **Subscription Model**: Premium users get full reports; free users receive highlights.

Approaches we used to build Sanrakshan

1. **Gemini AI API Approach**

   Initially, we used the **Gemini AI API** to assess risks, generate scores, analyze data handling and retention, and provide recommendations. While this approach provided useful insights, it had a major drawback—inconsistent scoring. Uploading the same privacy policy multiple times often resulted in different scores, reducing reliability.

2. **Custom Model Approach**

   To overcome this **inconsistency**, we shifted to a custom model. We fine-tuned **Legal-BERT** to classify privacy policy text into predefined categories and assign severity scores. This model now provides consistent and reliable predictions, improving the overall performance of Sanrakshan.

2. Requirement Specification and Analysis

Functional Requirements

- **User Onboarding system**
  - Users should be able to log in via Google OAuth.
- **Privacy Policy Upload and Management**
  - Users can upload PDF files containing privacy policies.
  - Secure storage and management of uploaded policies.
- **Uploaded document type analysis**
  - The system should validate whether the uploaded document is a privacy policy.
- **Privacy Policy Analysis**
  - The AI should analyze privacy policies and return structured results.
  - Identification of potentially harmful or non-compliant clauses.
  - Legal references and justifications for flagged sections.
- **Customized Reporting**
  - Detailed analysis reports highlighting flagged sections.
  - Explanations and references to applicable regulations (e.g., GDPR, CCPA).
- **Compliance Frameworks**
  - Regular updates to regulatory compliance standards.
- **Analysis and Insights**
  - Metrics on policy compliance (e.g., percentage of flagged sections).
  - Trends in privacy risks across analyzed policies.
  - Feedback collection from users to improve analysis accuracy.
- **Subscription Management**
  - Users should be able to subscribe for premium access.
  - Free users receive summary highlights, while premium users get full analysis.
  - Payments should be processed securely using Stripe.
- **Security and Access Management**
  - End-to-end encryption for data security.
- **AI Model Integration**
  - Usage of Gemini API
- **Support and Feedback**
  - Integrated support system for user queries.
  - Feedback collection to enhance platform features.

Non-Functional Requirements

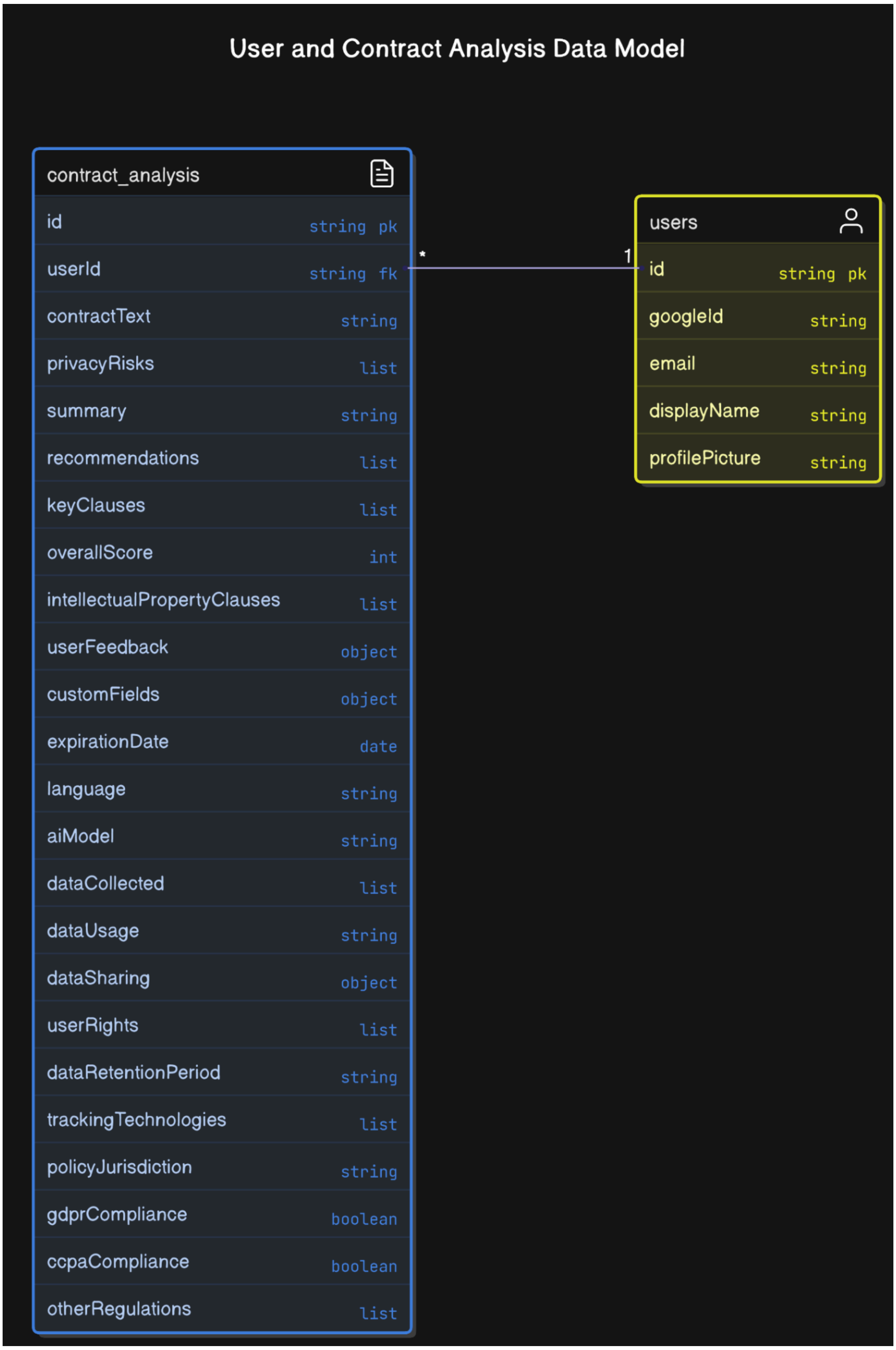
- The system should provide responses in **real-time**.
- Data should be **temporarily stored** in Redis for efficiency.
- The system must support **scalability** to handle multiple users.
- Security measures like **OAuth authentication and encrypted data storage** should be implemented.

Technology Stack

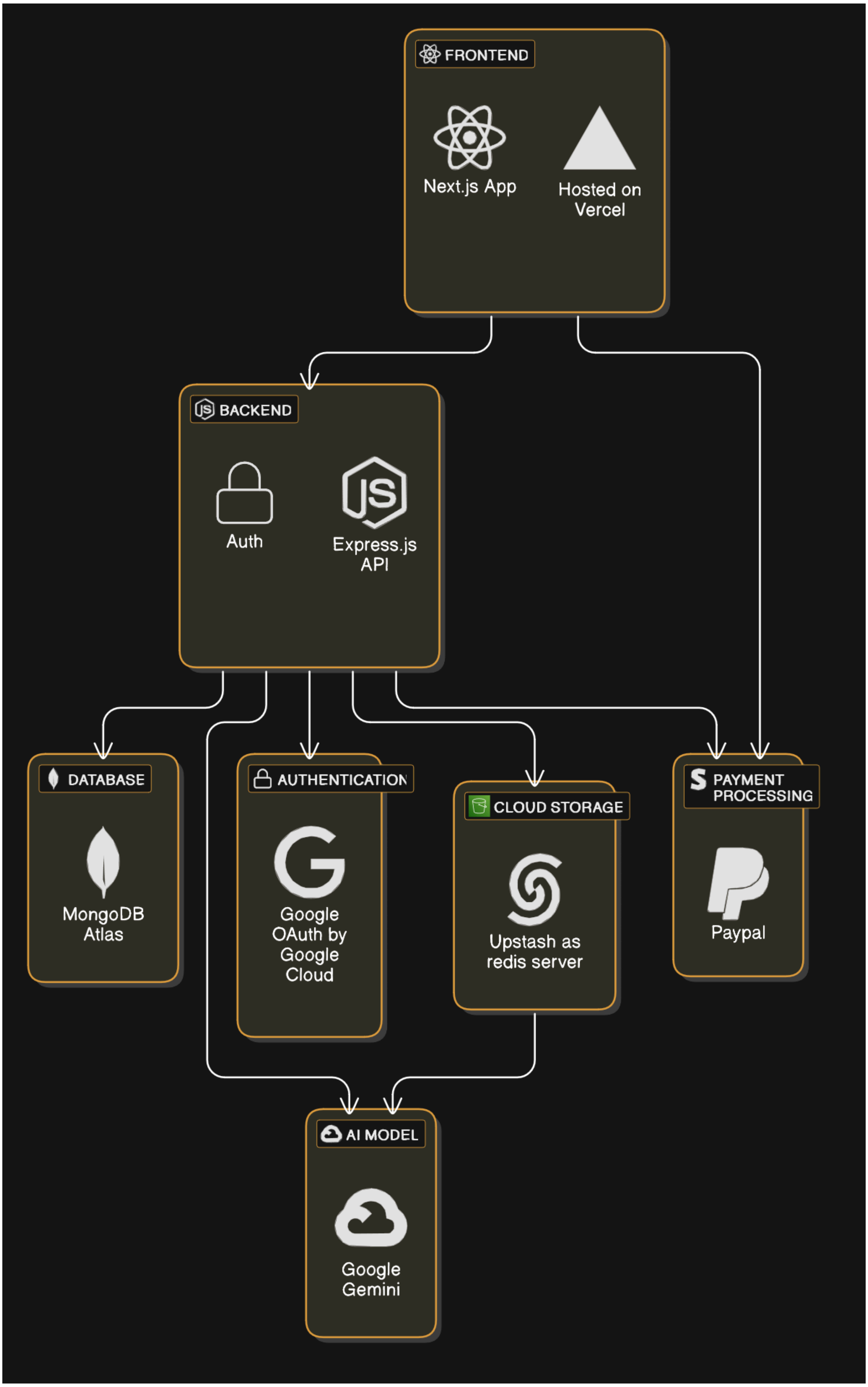
- **Frontend**: Next.js, React.js, Tailwind CSS , Shadcn UI library
- **Backend**: Express.js (Node.js)
- **Database**: MongoDB
- **Cache Storage**: Redis
- **AI Model**: Gemini AI API
- **Authentication**: Google OAuth2
- **Payment Processing**: Stripe

3. Design Diagrams

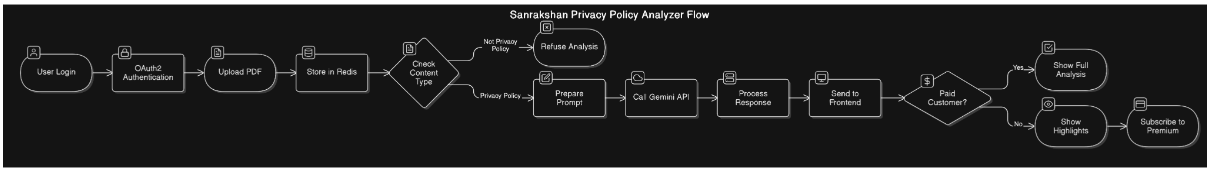
1. Database Diagram



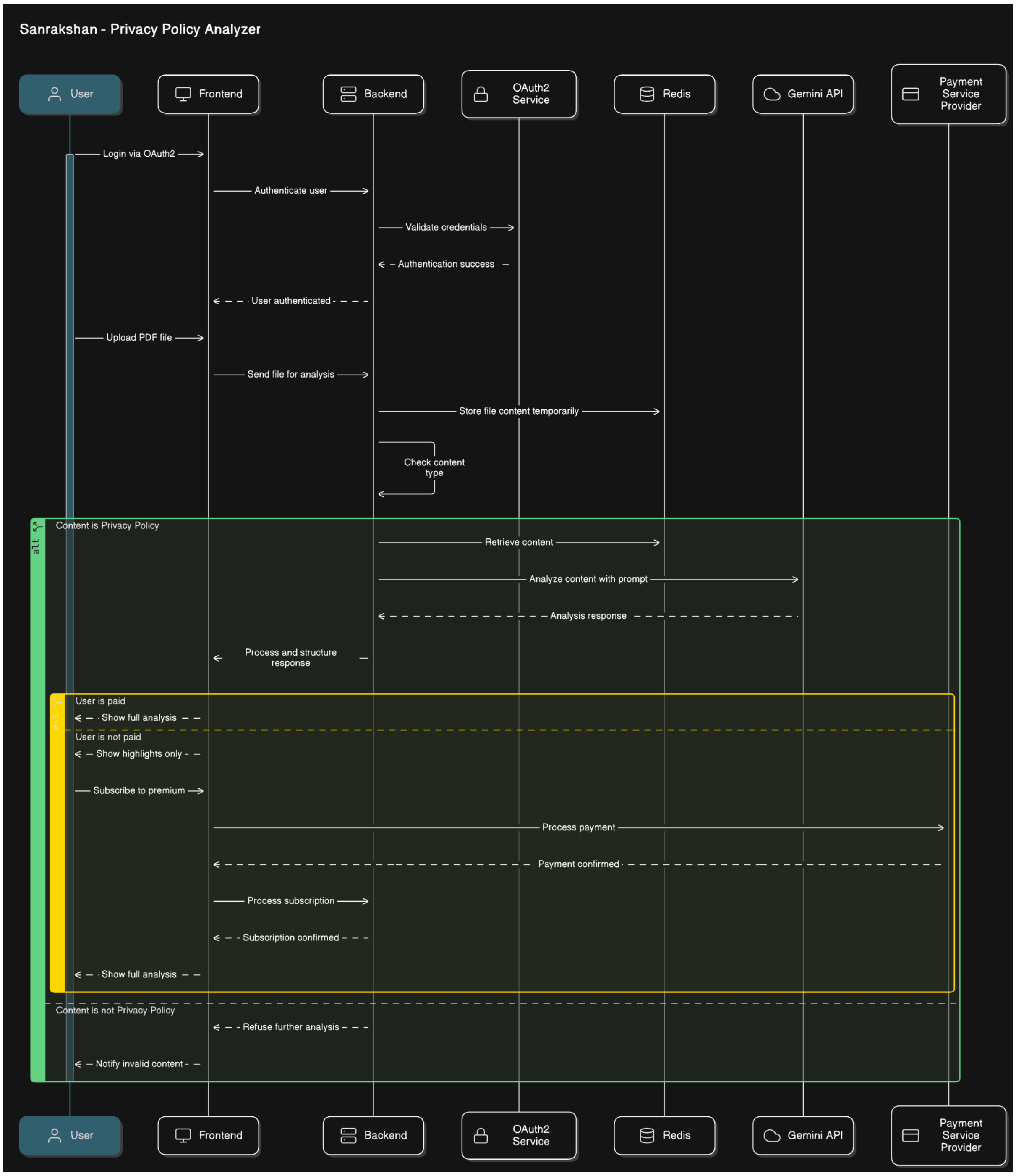
2. Application architecture



3.User application flow



4. Sequence Diagram



4. Implementation Details

Backend Implementation

- **Authentication**: Uses **Passport.js** with Google OAuth2.
- **File Handling**: Files are uploaded and stored **temporarily** in Redis.
- **AI Processing**: Extracted text is processed with **Gemini AI API**.
- **Response Handling**: AI responses are structured and categorized for easy interpretation.
- **Subscription Management**: Stripe integration manages user payments and access levels.

Frontend Implementation

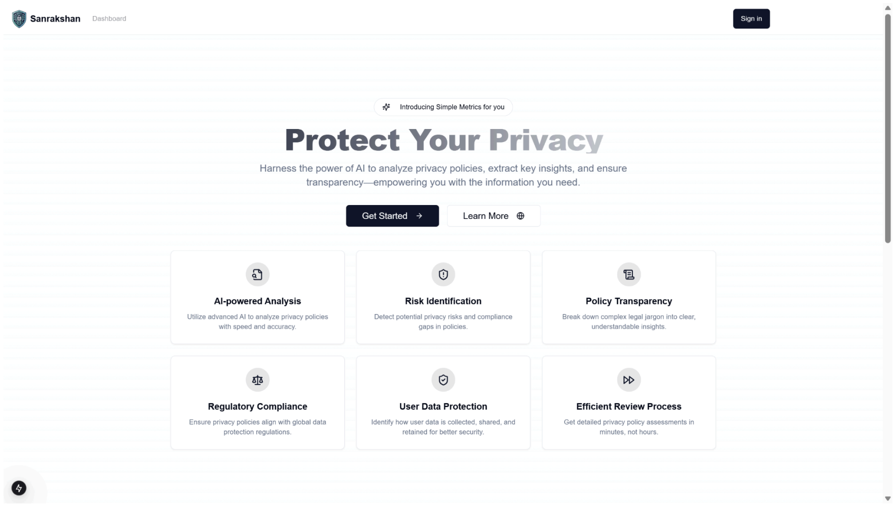
The frontend is built using **Next.js** and **React.js**, styled with **Tailwind CSS** for a modern UI. It includes:

- **Login Page**: Google OAuth2 authentication.
- **Dashboard**: Users can upload privacy policies.
- **Analysis Page**: Displays AI-generated insights.
- **Subscription Page**: Allows users to upgrade to premium.

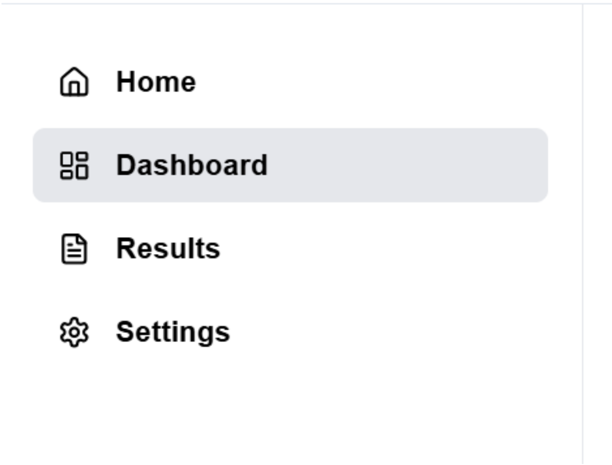
Graphical User Interface (GUI)

The application follows a **minimalist UI approach** for ease of use:

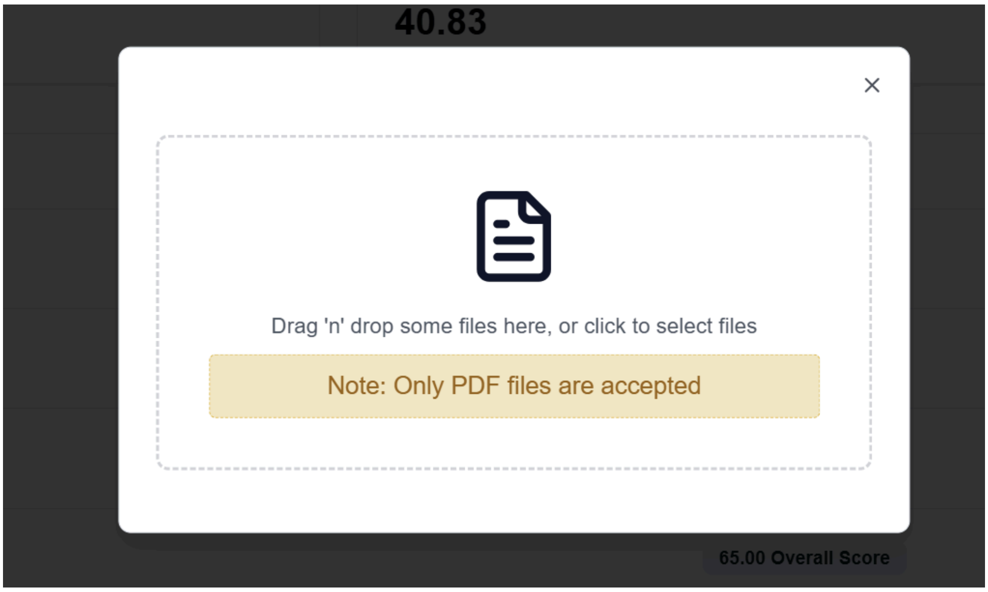
- **Home page**



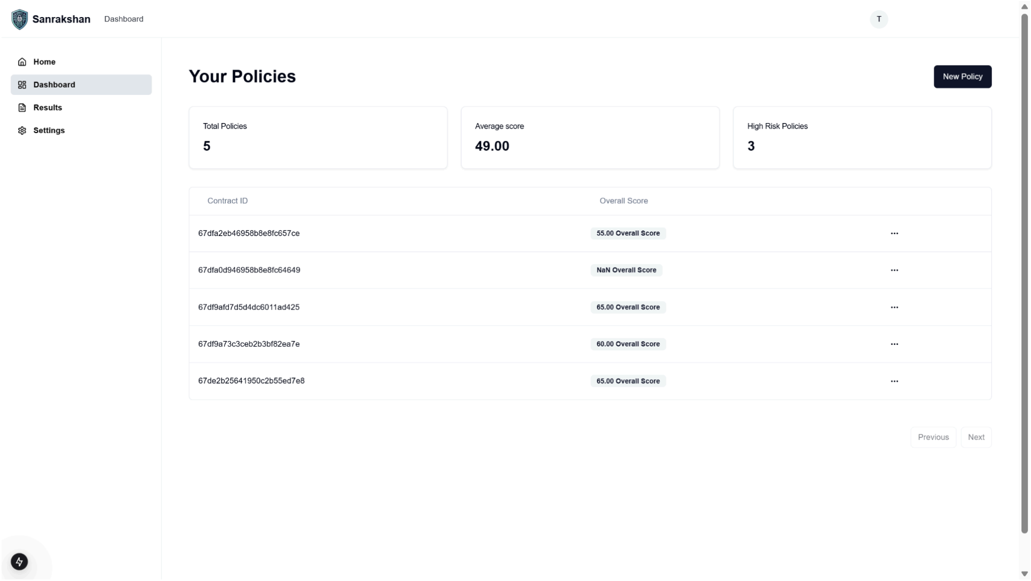
- **Navigation Bar**: Quick access to **Dashboard, Analysis, and Subscription** pages.



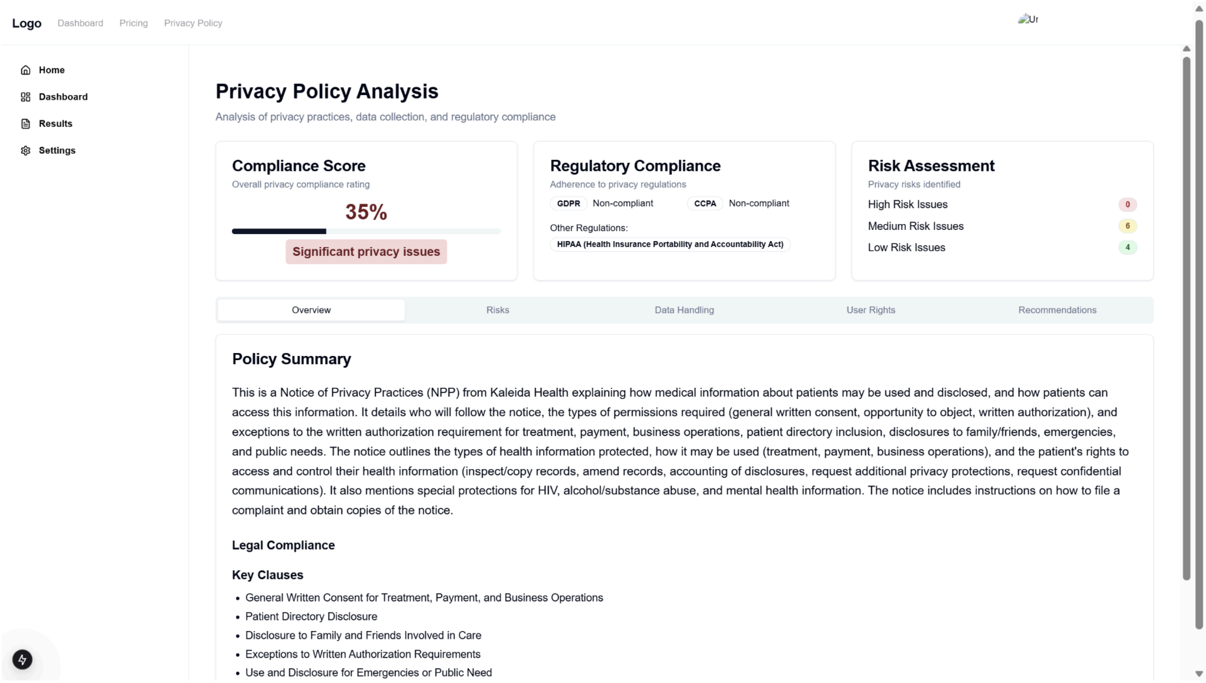
- **File Upload Section**: Users can drag & drop PDFs for analysis.

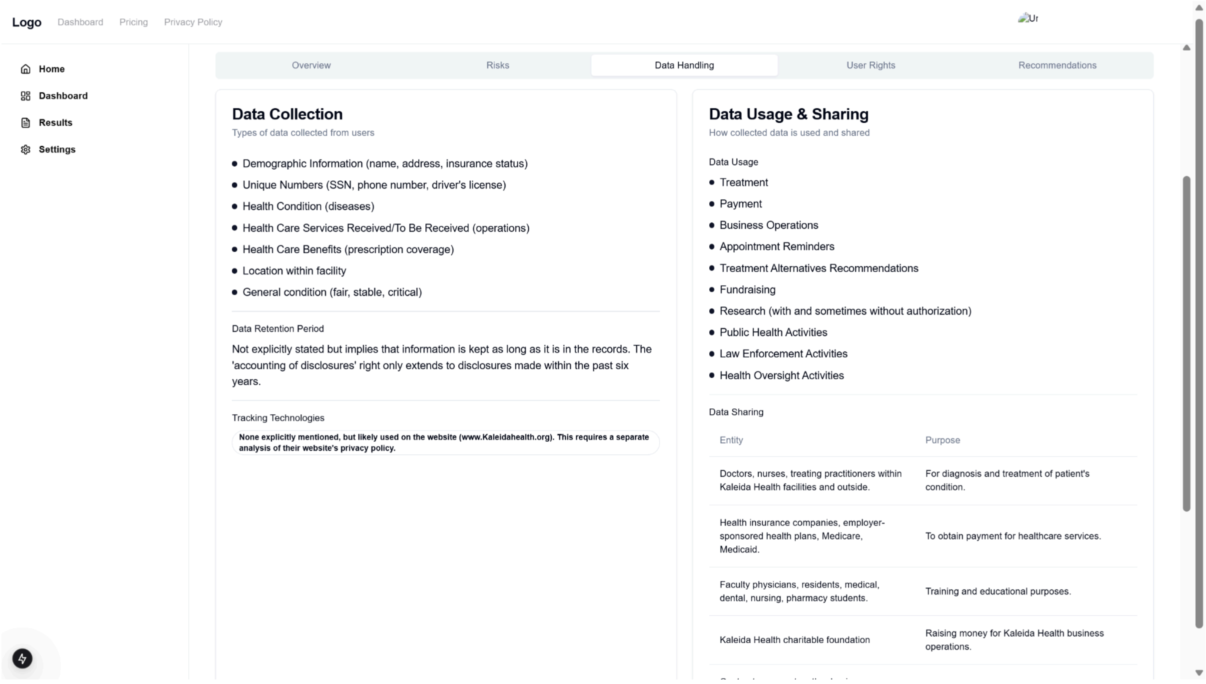


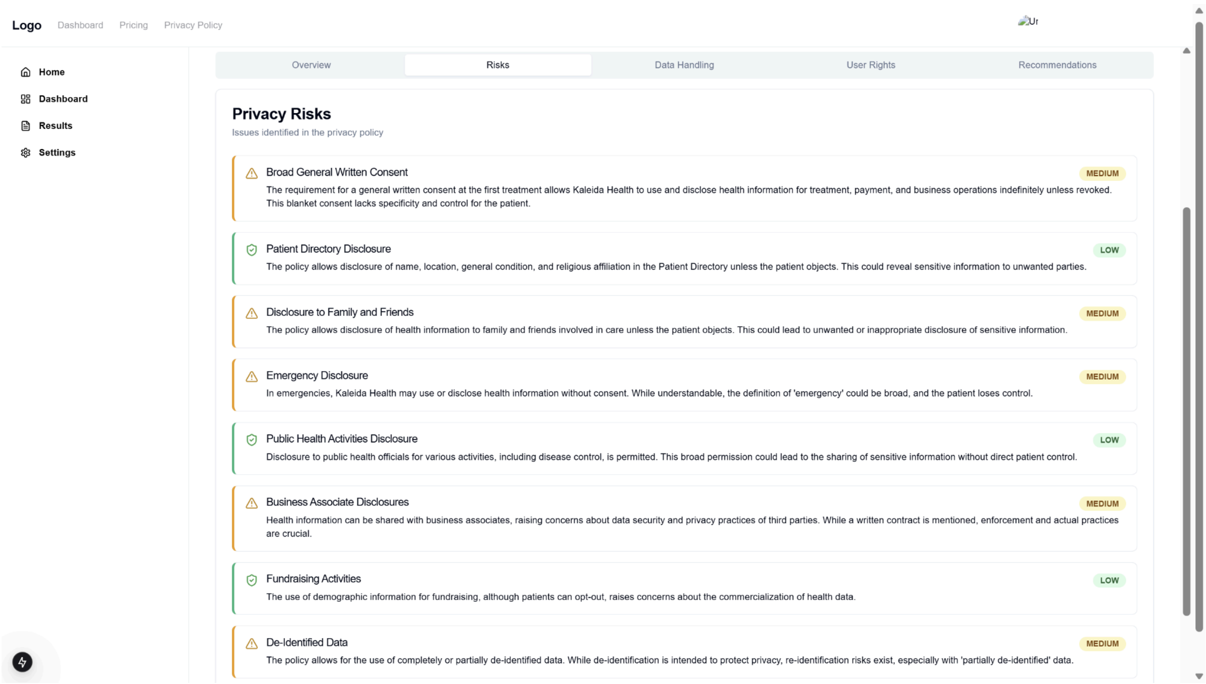
- **Dashboard Section:** Quick access to all the past analyzed privacy policies



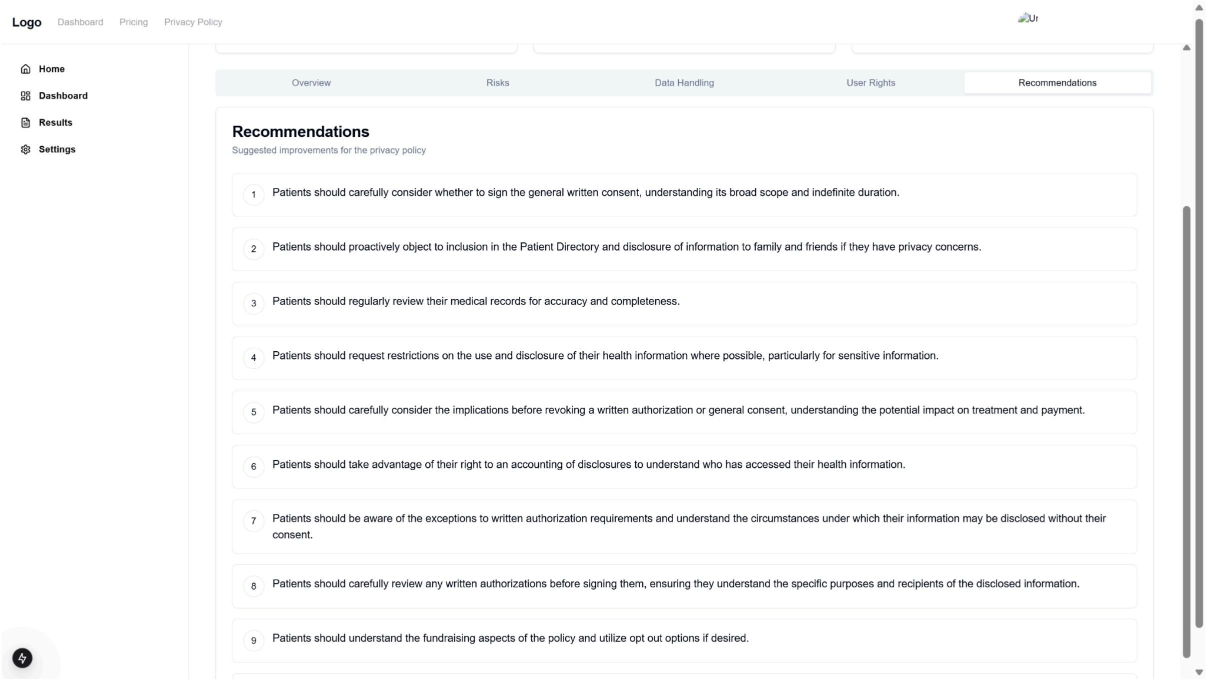
- **Analysis Display**: Highlighted key sections for free users; detailed breakdowns for premium users.



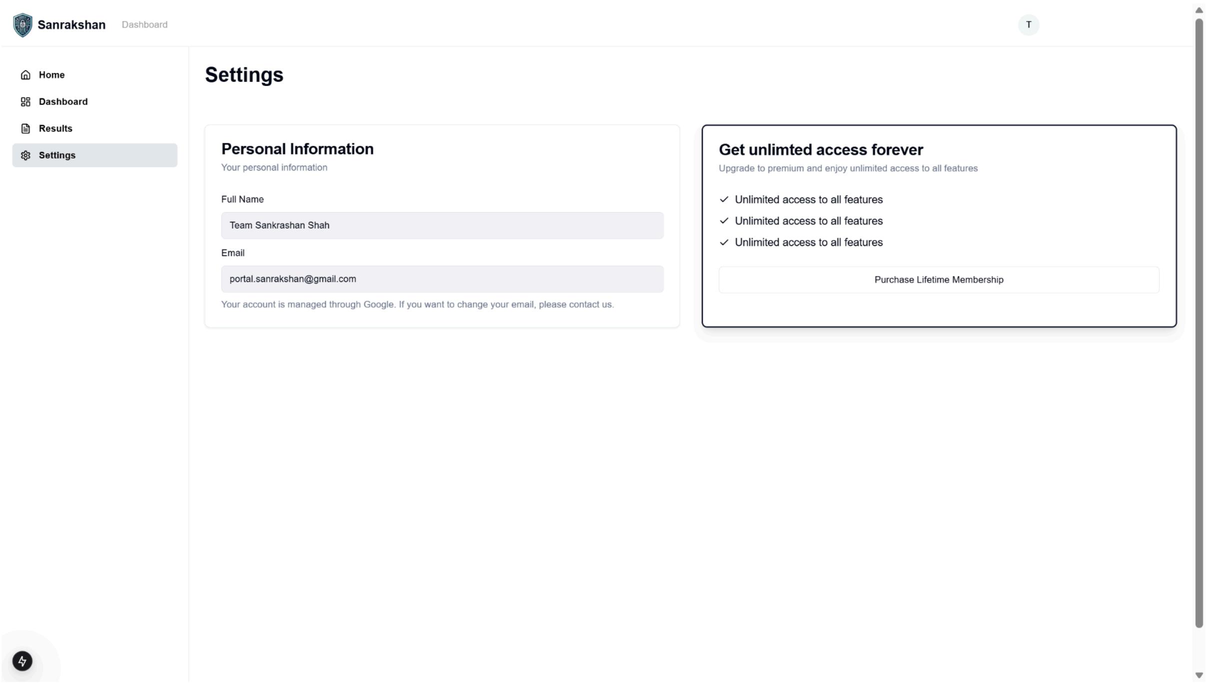




- **Recommendations section :** User will get suggestions how they can use app and what permissions they can opt-out from



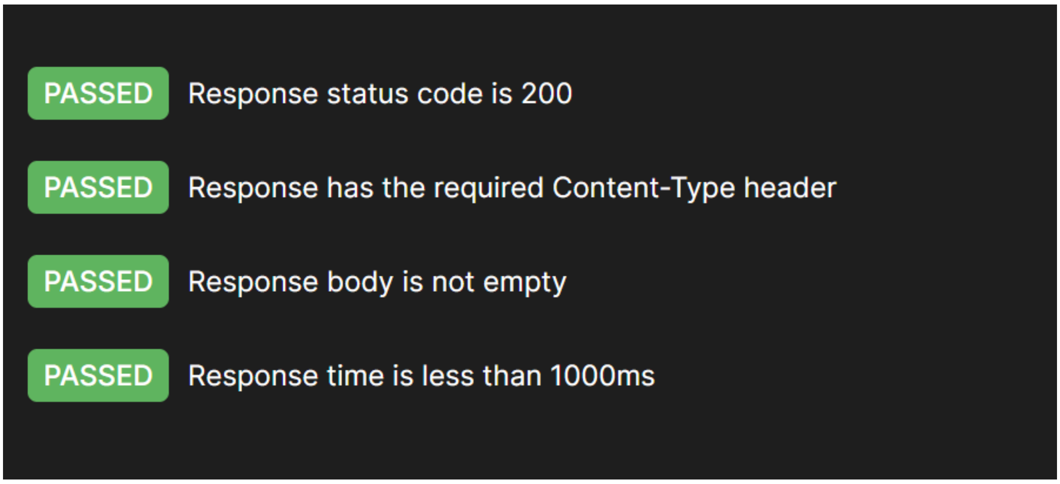
- **Subscription Section**: Users can upgrade their access via Stripe payment.



5. Testing

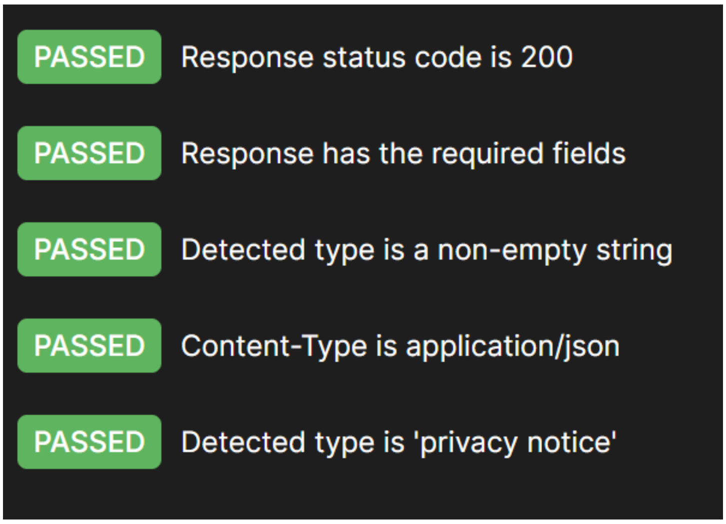
1. OAuth login

Api:/api/auth/google



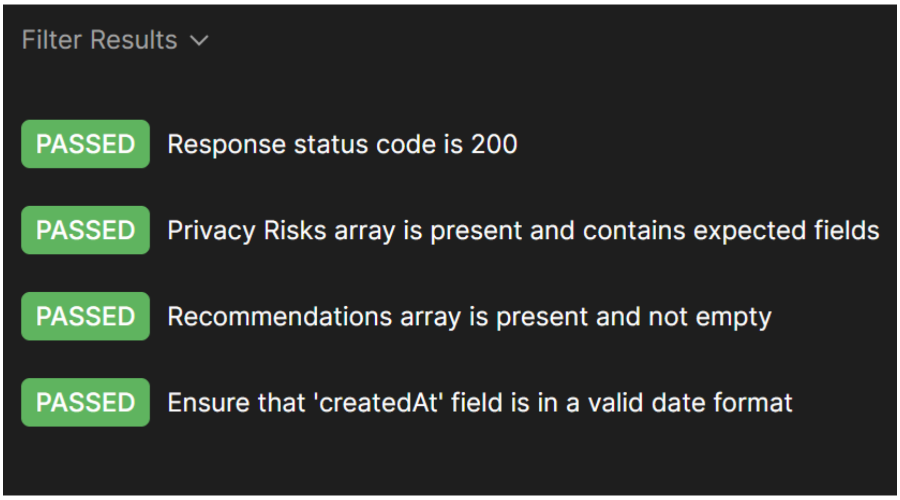
2. Detect type

Api:/api/policies/detect-type



3. Get User Contracts

Api:/api/policies/user-contracts



4. **Get analysis of past contract**

   Api:/api/policies/policy/:id

   - PASSED Response body structure is valid
   - PASSED Privacy risks array is present and has required fields
   - PASSED Data sharing array is present and has the required fields
   - PASSED User rights array is present and not empty
   - PASSED Tracking technologies array is present and is empty

5. **Delete privacy policy from history**

   Api: /api/policies/policy/:id

   - PASSED Response status code is 200
   - PASSED Response time is less than 200ms
   - PASSED Response schema matches the expected schema for contract deletion API

6. The Why section

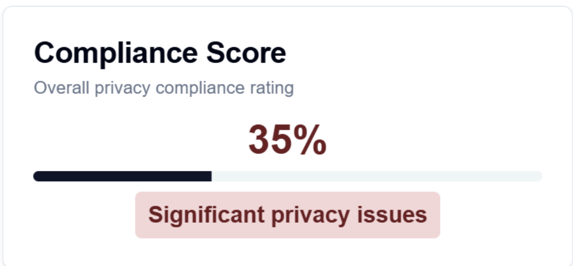
1. Why redis

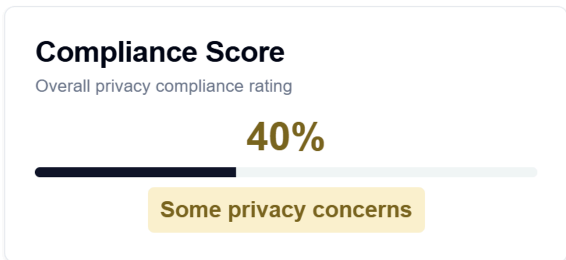
Option	Pros	Cons
Redis (Current Choice)	Fast, in-memory, auto-expiry	Limited storage, not for large files
S3/Cloud Storage	Scalable, durable	Slower retrieval, requires network call
MongoDB	Document oriented storage	Slower queries, more storage overhead
Local File System	Simple	Doesn’t work well in multi-server environments

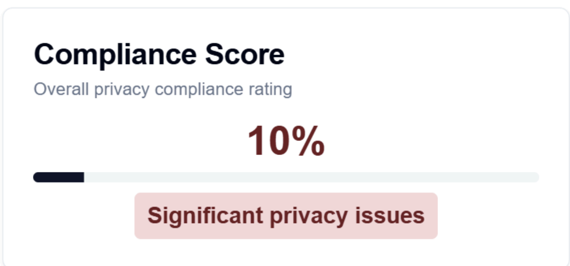
Our use case fits Redis because:

- We **don’t need long-term storage**.
- We **prioritize speed** over persistence.
- The files are **temporary and don’t need backups**.

2. Why different score for same policy







1. LLMs Are Not Deterministic

- Gemini, like other AI models, doesn't always generate the same response for the same input.
- Even slight variations in wording can result in different interpretations and scores.

2. Lack of a Standardized Scoring Mechanism

- Gemini isn't specifically fine-tuned for legal contract scoring.
- It relies on general legal knowledge but doesn't have a structured numerical evaluation system.

3. Context Dependence

- The same privacy policy section might get a higher score if asked in one context and a lower score in another.
- AI models often "hallucinate" risk factors that may or may not be present.

4. Temperature and Randomness

- AI models use a temperature setting (which controls randomness in responses).
- If Gemini's API has a non-zero temperature, it may generate slightly different outputs each time.

That's why we are building our own Model

Example: Gemini vs. Our Own Model

Privacy Policy Clause	Gemini Output (Inconsistent)	Our Model Output (Consistent)
"We may share data with third-party partners for marketing."	Score: 4/10 (First run) Score: 7/10 (Second run)	Score: 6/10 (Fixed, based on risk level)
"We store your data indefinitely for service improvement."	Score: 5/10 (First run) Score: 3/10 (Second run)	Score: 4/10 (Based on data retention risks)
"Users can request deletion of their data anytime."	Score: 8/10 (First run) Score: 6/10 (Second run)	Score: 7/10 (Consistent with GDPR compliance)

7. Literature Review

Summary of Necessary Algorithms

To achieve effective classification of privacy policy texts, various Natural Language Processing (NLP) and deep learning techniques are explored:

- **Legal-BERT**: A transformer-based model fine-tuned for legal text classification. The model used in this project is **Legal-BERT-Base-Uncased** from Hugging Face (Legal-BERT Model). It is trained specifically on legal texts to improve classification performance. The model is based on the research by Chalkidis et al. (2020).

8. Algorithms Implemented

The following algorithms and models were implemented in Sanrakshan:

- **Legal-BERT**: Fine-tuned for privacy policy classification into categories such as First Party Collection/Use, Data Retention, Third Party Sharing/Collection, etc.

9. Datasets, Tools, and Technologies Used

Datasets

- **OPP-115 Corpus**: A dataset consisting of 115 website privacy policies annotated by three legal experts. It provides structured annotations for data practices, making it ideal for supervised learning tasks in privacy policy classification. The dataset is publicly available for research and academic purposes.

Tools and Technologies

- **Programming Language**: Python
- **Libraries**: TensorFlow, PyTorch, Hugging Face Transformers, Scikit-learn, NLTK
- **Development Environment**: Jupyter Notebook, PyCharm Professional (for running notebooks locally, handling CSV files, and running the model locally)
- **Operating System**: Fedora, Ubuntu

10. Implementation Details

Sanrakshan consists of:

- **Data Preprocessing**: Tokenization and label encoding.

- **Model Training and Evaluation**: Training the Legal-BERT model with fine-tuning.

    - **Legal-BERT Training Configuration**:

        - **Evaluation Strategy**: Steps-based evaluation every 500 steps.
        - **Batch Size**: 20 for both training and evaluation.
        - **Learning Rate**: 1e-5 to ensure stable training.
        - **Epochs**: 3 for optimal fine-tuning.
        - **Weight Decay**: 0.01 for better generalization.
        - **Logging and Checkpointing**:
            - Logs every 100 steps.
            - Saves model every 500 steps, keeping the last 2 checkpoints.
            - Loads the best model at the end.
        - **Evaluation Metrics**: Accuracy and F1-score for classification performance.

Preprocessing Steps

Sanrakshan processes privacy policy annotations by extracting relevant text and categories from annotated CSV files. The preprocessing involves:

1. **Extracting Categories and Selected Text:**

    - Scans all CSV files in the annotation directory.
    - Extracts category information from the 6th column and parses JSON data in the 7th column.
    - Stores extracted selectedText values along with the category.

2. **Extracting Categories, Selected Text, and Values:**

    - Further extracts the value field from the JSON structure in the annotations.
    - Ensures that both the text and its associated value are retained for better analysis.
3. **Cleaning Processed Annotations:**

    - Removes rows where SelectedText is null to ensure the final dataset is clean and meaningful.
    - Saves the cleaned data in a final annotation directory for model training.

Combining and Processing Annotation CSVs

The annotated privacy policy texts are stored in multiple CSV files, which are combined into a single dataset for model training:

1. **Merging Multiple CSV Files:**
   - Reads all CSV files from the annotation directory and merges them into a single dataset.
   - Ensures all annotations are included in one dataset for model training.

2. **Shuffling the Data:**
   - The dataset is shuffled randomly to ensure a balanced distribution of categories and to prevent any bias during training.

3. **Removing Duplicates:**
   - Removes duplicate rows from the dataset to maintain uniqueness and improve model efficiency.
   - Saves the deduplicated dataset as deduplicated_combined_dataset.csv.

4. **Extracting Unique Rows:**
   - Identifies unique rows from the dataset without modifying the original dataset.
   - Saves the unique rows separately in unique_rows_dataset.csv.

5. **Dataset Statistics:**
   - Displays the number of CSV files processed and the number of rows after deduplication.

Privacy Score Calculation

To assess privacy compliance, we designed a **Privacy Score formula** that evaluates different aspects of a policy. A **higher score indicates better privacy compliance**, while a **lower score suggests privacy risks**.

Formula for Privacy Score Calculation

$$\text{Privacy Score} = w_1F + w_2T + w_3U + w_4O + w_5A + w_6P + w_7R + w_8S + w_9I + w_{10}D$$

Since privacy-invasive actions reduce user privacy, our formula assigns **positive weights** to risk-increasing factors and **negative weights** to privacy-enhancing factors.

However, since the raw **Privacy Score** can vary, we **normalize** it to a **0-100 scale**, making interpretation easier:

$$\text{Final Privacy Score} = \left(\frac{\text{Privacy Score} - \text{Min Possible Score}}{\text{Max Possible Score} - \text{Min Possible Score}} \right) \times 100$$

where:

- **Max Possible Score (Best Case):** −5.5-5.5
- **Min Possible Score (Worst Case):** 7.17.1
- **Higher scores indicate better privacy compliance.**

Weight Assignments for Privacy Categories

Category	Variable	Weight (w)	Reasoning
First Party Collection/Use	**F**	1.2	Higher collection = lower privacy
Third Party Sharing/Collection	**T**	1.5	Third-party sharing is riskier
User Choice/Control	**U**	-1.5	More user control = better privacy
Other	**O**	1.0	Miscellaneous privacy impact
User Access, Edit, and Deletion	**A**	-1.2	More access rights = better privacy
Policy Change	**P**	1.0	Frequent changes weaken privacy

Data Retention	**R**	1.3	Longer retention = higher risk
Data Security	**S**	-1.8	Stronger security = better privacy
International and Specific Audiences	**I**	1.1	May increase legal complexity
Do Not Track	**D**	-1.0	Respecting DNT improves privacy

GUI (testing screenshots)

```
Text: We collect user data for analytics.
Actual Category: First Party Collection/Use
Predicted Category: First Party Collection/Use

Text: This site does not respond to Do Not Track signals.
Actual Category: Do Not Track
Predicted Category: Do Not Track

Text: Users can update or delete their personal information.
Actual Category: User Access, Edit and Deletion
Predicted Category: User Access, Edit and Deletion

Text: We may share your data with third-party service providers for analytics purposes.
Actual Category: Third Party Sharing/Collection
Predicted Category: Other

Text: We will not use your camera but we will take pictures of you every 2 mins for improvement of our platform
Actual Category: First Party Collection/Use
Predicted Category: First Party Collection/Use
```

Breakdown of the Results

Each test case consists of:

1. **Text:** The actual input privacy policy statement.
2. **Actual Category:** The correct category assigned to the statement based on annotations.
3. **Predicted Category:** The category assigned by the Legal-BERT model.

Observations from the Results

1. **"We collect user data for analytics."**

    - **Actual Category:** First Party Collection/Use
    - **Predicted Category:** First Party Collection/Use
    - **Correct classification**
    - Since the sentence directly states data collection for analytics, the model correctly identifies it as "First Party Collection/Use."

2. **"This site does not respond to Do Not Track signals."**

    - **Actual Category:** Do Not Track
    - **Predicted Category:** Do Not Track
    - **Correct classification**
    - The model successfully recognizes the relevance of "Do Not Track" policies.

3. **"Users can update or delete their personal information."**

    - **Actual Category:** User Access, Edit and Deletion
    - **Predicted Category:** User Access, Edit and Deletion
    - **Correct classification**
    - The model correctly maps this to "User Access, Edit and Deletion" since it discusses modifying personal information.

4. **"We may share your data with third-party service providers for analytics purposes."**

    - **Actual Category:** Third Party Sharing/Collection
    - **Predicted Category:** Other
    - **Incorrect classification**
    - The model fails to classify this under "Third Party Sharing/Collection" and instead assigns it as "Other."
    - **Possible Reason:** The model may not have seen enough similar examples during training or might be sensitive to specific phrasing.

5. **Custom Test Case:** "We will not use your camera but we will take pictures of you every 2 mins for improvement of our platform."

    - **Actual Category:** First Party Collection/Use
    - **Predicted Category:** First Party Collection/Use
    - **Correct classification**
    - This is a deliberately vague and tricky statement.
    - The model correctly identifies that even though "camera" usage is denied, the company is still collecting images, making it a **"First Party Collection/Use"** case.

11. Testing Results and Discussion

- **Evaluation Metrics**: The classification models were evaluated using accuracy and F1-score. **Results**:
    - **Final Evaluation Scores**:
        - **Validation Loss**: 0.8804
        - **Accuracy**: 0.6815
        - **F1-score**: 0.6741

    - Legal-BERT outperformed traditional ML methods with high accuracy.

- **Interpretation of Results:**

    - The **validation loss (0.8804)** indicates how well the model generalizes to unseen data. A lower value suggests better generalization, but there is still room for improvement.

    - The **validation loss (0.8804)** indicates how well the model generalizes to unseen data. A lower value suggests better generalization, but there is still room for improvement.

    - The **accuracy score (68.15%)** reflects the proportion of correctly classified instances, showing that Legal-BERT performs significantly better than traditional ML models for this task.

    - The **F1-score (67.41%)** balances precision and recall, ensuring that the model minimizes both false positives and false negatives.

    - While the scores are promising, further improvements in **data preprocessing, fine-tuning, and dataset diversity** could enhance the model's performance.

- **Challenges**:

    - **Fine-tuning Legal-BERT for optimal performance**: Optimizing the model required extensive hyperparameter tuning and experimentation to achieve the best classification accuracy.

    - **Difficulty in finding a suitable dataset**: Many available datasets were either not well-annotated or lacked proper filtering, making preprocessing and data cleaning more challenging.

    - **Lack of newly annotated privacy policy datasets**: Most of the publicly available datasets are outdated and do not reflect the evolving landscape of AI-driven data collection and modern privacy concerns. This limits the model's ability to generalize well to contemporary privacy policies.

12. Conclusion

Sanrakshan successfully automates privacy policy analysis, making legal documents more accessible. By utilizing transformer-based models like Legal-BERT, it significantly improves classification accuracy over traditional ML techniques. This project contributes to enhancing user awareness and transparency in privacy policies.

Moreover, our model effectively handles ambiguous or misleading privacy statements, ensuring consistency in classification. For instance, in cases where a company denies **camera usage** but still collects images, the model accurately identifies it under **First Party Collection/Use**. This highlights the importance of Sanrakshan in tackling such challenges and maintaining a standardized approach to privacy policy analysis. By leveraging **Legal-BERT**, we provide a reliable and structured way to analyze privacy policies, helping both users and regulators make informed decisions.

Future Extensions

While Sanrakshan has demonstrated strong performance in privacy policy classification, there is still room for improvement and expansion:

- **Multilingual Support**: Expanding the model to classify privacy policies in multiple languages to cater to a global audience.

- **Summarization Module**: Integrating a summarization feature to provide users with concise, user-friendly insights from lengthy privacy policies.

- **Explainability & Interpretability**: Enhancing model explainability by providing insights into why a particular classification was made.

- **Real-Time API Integration**: Deploying the model as an API that can be integrated into websites and applications for instant privacy policy analysis.

- **Severity Scoring Refinement**: Improving severity scoring mechanisms to provide more granular risk assessments of different privacy practices.

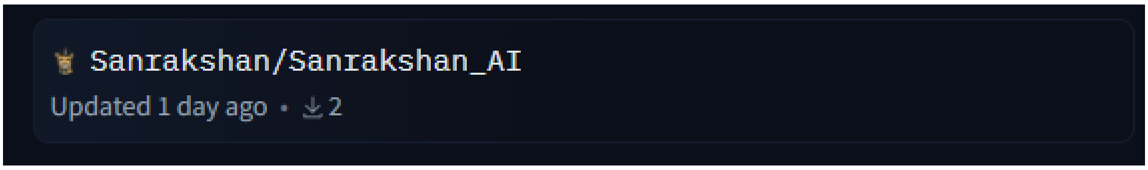
- **Dataset Expansion**: Continuously updating the training dataset with newly published privacy policies to improve model robustness and adaptability.

These future enhancements will further strengthen Sanrakshan's capability to analyze privacy policies effectively, making privacy awareness more accessible and actionable for users worldwide.

13. Sanrakshan Model on Hugging Face

The trained Legal-BERT model for Sanrakshan is available on Hugging Face at:
[Sanrakshan AI on Hugging Face](#)

This model has been fine-tuned for privacy policy classification, enabling automated categorization of policy texts into predefined categories with assigned severity labels. Researchers and developers can leverage this model to enhance privacy policy understanding, integrate it into legal tech applications, or further fine-tune it for related tasks.



References

Chalkidis, Ilias, Manos Fergadiotis, Prodromos Malakasiotis, Nikolaos Aletras, and Ion Androutsopoulos. "LEGAL-BERT: The Muppets straight out of Law School." *Findings of the Association for Computational Linguistics: EMNLP 2020* (2020): 2898-2904. DOI: 10.18653/v1/2020.findings-emnlp.261.

Wilson, Shomir, et al. "The creation and analysis of a website privacy policy corpus." *Proceedings of the 54th Annual Meeting of the Association for Computational Linguistics*, Berlin, Germany, August 2016.

Appendix: OPP-115 Corpus Information

Usage Information

If you use this dataset as part of a publication, you must cite the following paper:

The creation and analysis of a website privacy policy corpus. Shomir Wilson, et al. *Proceedings of the 54th Annual Meeting of the Association for Computational Linguistics*, Berlin, Germany, August 2016.